INCIDENT EVIDENCE WALKTHROUGH

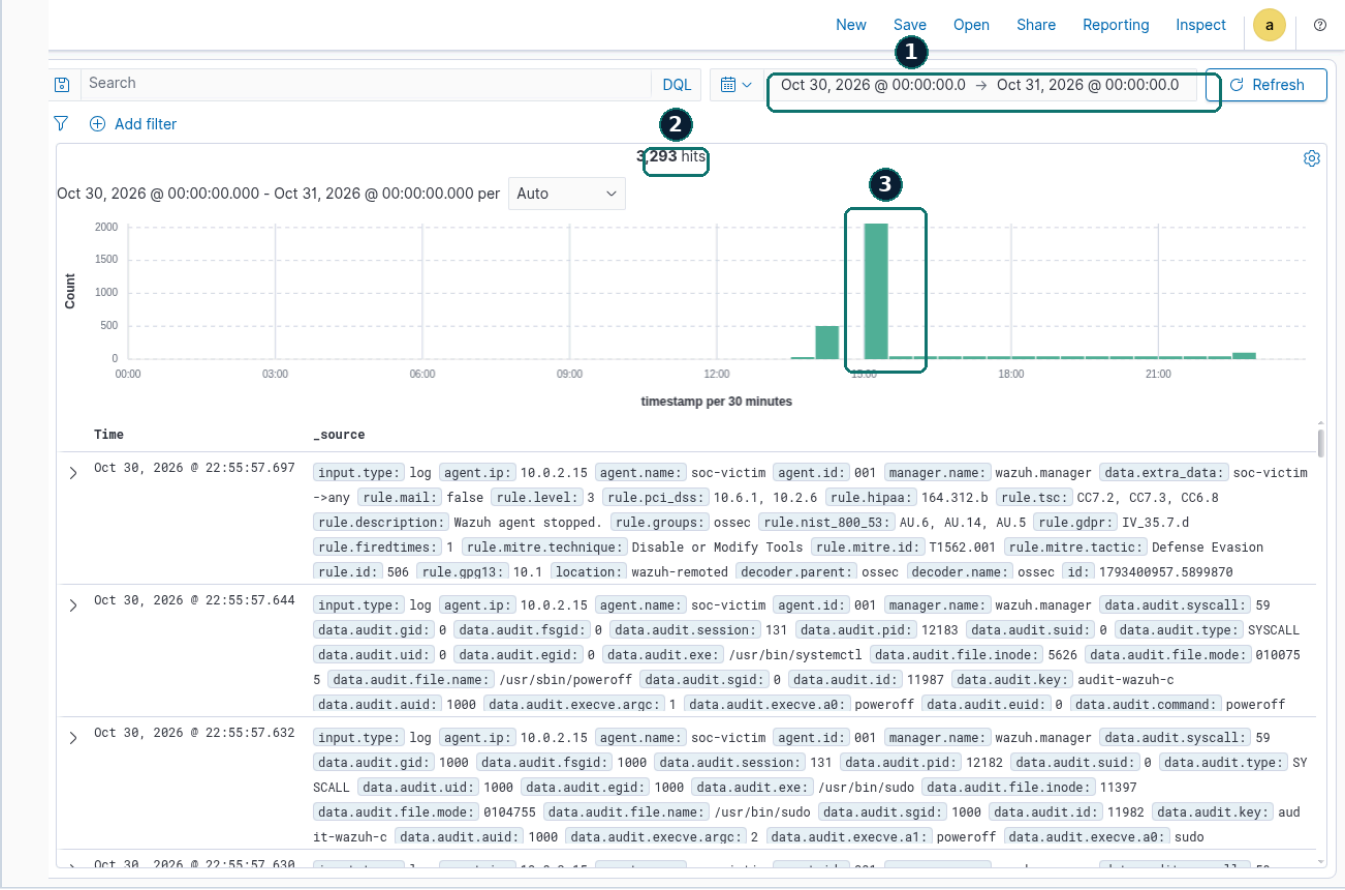
SSH brute force to key persistence

INC-001 · High severity · 30 October 2026 · soc-victim

3	20	34	1
rules fired	failed passwords	seconds to login	key persisted

1. Start with the whole day

Open Discover with no query and a 24 hour window. The endpoint produced 3,293 alerts on 30 October. One block stands out from a mostly flat day.



1. Full day in UTC, no filters and no custom rules.
2. 3,293 alerts, mostly level 3 PAM and sudo chatter.
3. One block at 15:00 carries about 2,000 alerts. That is the attack window, and it is the only thing on the day that looks like a burst.

WHAT TO LOOK FOR IN THE LOGS

Shape against baseline

A tall block on an otherwise flat line. Routine activity has small, regular peaks.

Level mix

The block carries level 12 events. The flat line is level 3.

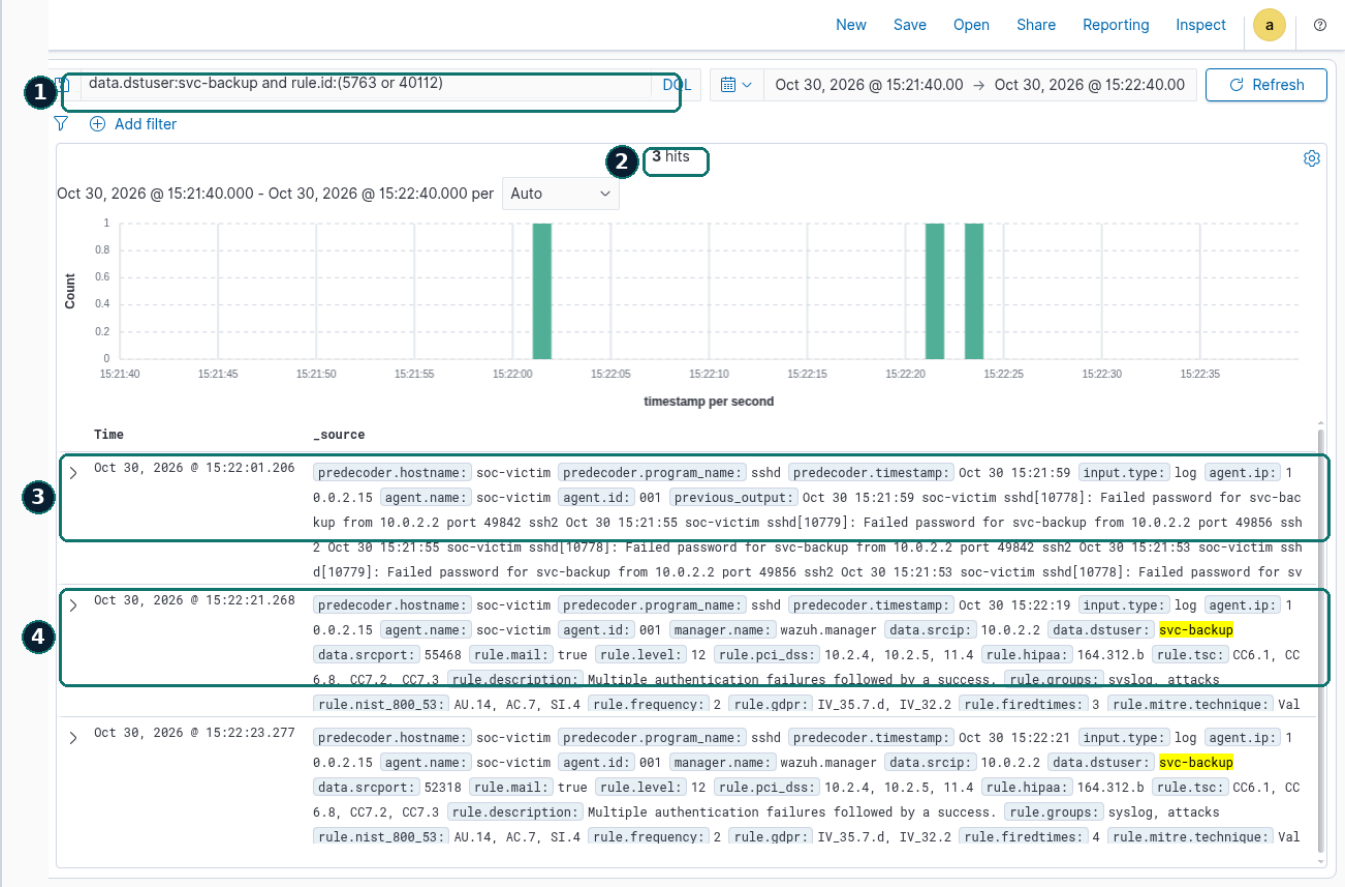
Agent and account

One agent, soc-victim. Inside the block, one account repeats.

> This is the perspective step. Without it, a four minute window looks as busy as the rest of the day and the analyst has no sense of scale.

2. Narrow to the minute, stock rules only

Two rules that ship with Wazuh are enough to name the behaviour. 5763 reports the brute force, 40112 reports a success after failures. No custom rule is used yet.



1. Stock rule IDs plus the target account. The account clause is what removes the noise.
2. Three hits. Without the account clause the same query returns seven, and four of those are analyst logins.
3. 5763 at 15:22:01. The previous_output field holds the failed password lines, so the count comes from the alert itself.
4. 40112 at 15:22:21. Same account, one second before the file change.

WHAT TO LOOK FOR IN THE LOGS

One account, one source

Twenty failures in 31 seconds from 10.0.2.2. A person mistyping does not produce that shape.

Success after failure

The 40112 row at 15:22:21 is the incident. Everything before it is attempt.

Read previous_output

The row carries the raw failed lines. Quote them in the ticket instead of the rule text.

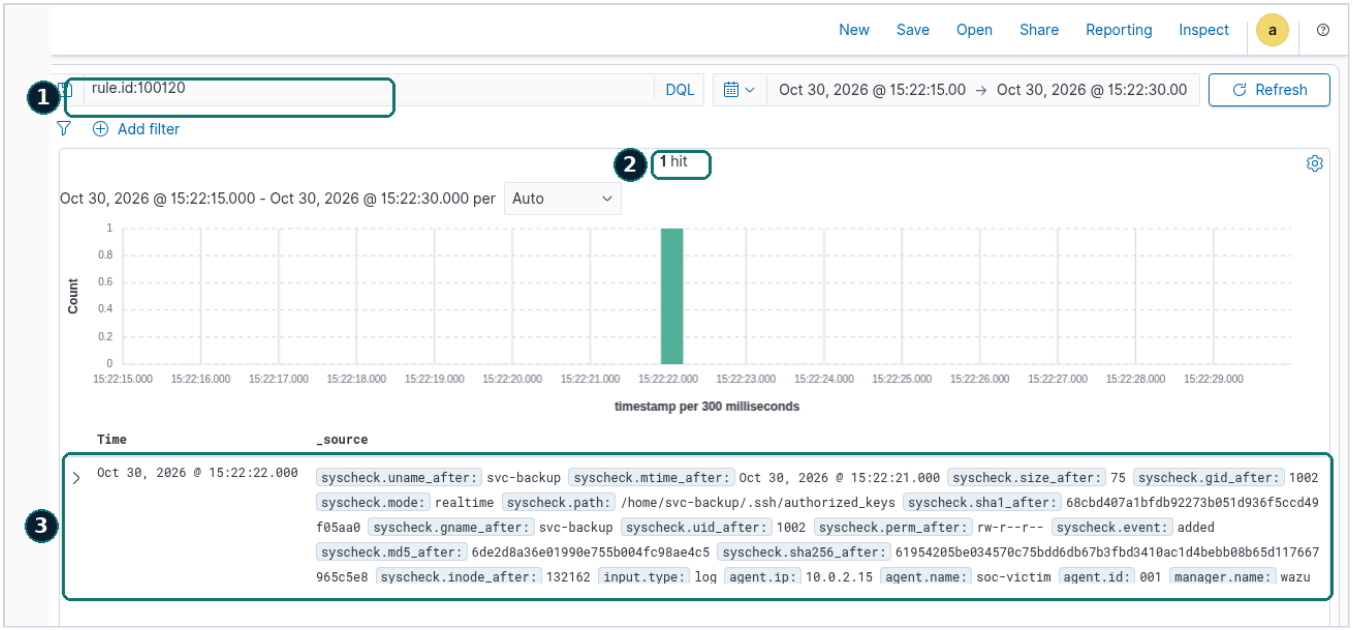
Expect false positives

At this volume the rule also fires on analyst logins. The account filter separates them.

> Stock rules name the behaviour but not the impact. They do not say what the attacker did after login. That is the next step.

3. Apply the custom rule

Rule 100120 was written for this lab. It reports a change to authorized_keys, which the stock ruleset does not cover.



1. Query on the custom rule only, in a 15 second window.
2. One hit, one second after the successful login.
3. The full syscheck record, including path, event, size, mtime, and hashes.

WHAT TO LOOK FOR IN THE LOGS

Event and mode

added, realtime. A modification would mean an existing key list changed.

Path and owner

Under the service account home. A backup account should not hold an authorized_keys file.

Size and mtime

75 bytes at 15:22:21. The alert reports 15:22:22 because FIM batches writes.

Hash

SHA-256 in the same event. Record it before the file is removed.

> A custom rule is justified only when it adds a fact the stock rules miss. Here the fact is the key, and the hash that proves which key it was.

4. The alert chain, exported

The same window exported from the manager and printed one line per alert. This is the evidence set quoted in the ticket.

soc-lab, INC-001, alert timeline, UTC

```
$ jq -r '.[] | select(.rule.id=="5763" or .rule.id=="40112" or .rule.id=="100120")
      | "\(.timestamp[11:19])  \(.rule.id)  L\(.rule.level)  \(.rule.description)"' \
      docs/evidence/INC-001-alerts.json
15:22:01  5763  L10  sshd: brute force trying to get access to the system. Authentication
failed.
15:22:03  40112  L12  Multiple authentication failures followed by a success.
15:22:05  40112  L12  Multiple authentication failures followed by a success.
15:22:21  40112  L12  Multiple authentication failures followed by a success.
15:22:22  100120  L12  FIM: SSH authorized_keys added or modified (possible persistence)
15:22:23  40112  L12  Multiple authentication failures followed by a success.
15:22:35  40112  L12  Multiple authentication failures followed by a success.
15:22:35  40112  L12  Multiple authentication failures followed by a success.
15:23:05  40112  L12  Multiple authentication failures followed by a success.
15:23:05  40112  L12  Multiple authentication failures followed by a success.
```

1. 5763 at 15:22:01 marks the password burst. Twenty failures arrived in 31 seconds.
2. 40112 at 15:22:21 is the success that followed them.
3. 100120 one second later is persistence, not more guessing.
4. The remaining 40112 rows belong to analyst sessions on the same shared gateway.

ALERT MIX

RULE	ALERTS	WHAT IT ADDS
5763	1	The burst is recognised as a brute force
40112	8	One real success and seven analyst false positives
100120	1	The key change that outlives the password

> Rule 40112 fires on any success after failures, including a normal login from a busy address. Correlate it with the account and the second that follows, never on its own.

5. File evidence

The FIM record is the part that survives a password reset. Capture the path, the time, the size, and the hash before anything is deleted.

soc-lab, INC-001, file integrity record

```
$ jq '.[] | select(.rule.id=="100120") | {timestamp, path: .syscheck.path,
      event: .syscheck.event, mode: .syscheck.mode, size: .syscheck.size_after,
      mtime: .syscheck.mtime_after, sha256: .syscheck.sha256_after}' \
      docs/evidence/INC-001-alerts.json
{
  "timestamp": "2026-10-30T15:22:22.000+0000",
  "path": "/home/svc-backup/.ssh/authorized_keys",
  "event": "added",
  "mode": "realtime",
  "size": "75",
  "mtime": "2026-10-30T15:22:21",
  "sha256": "61954205be034570c75bdd6db67b3fbd3410ac1d4bebb08b65d117667965c5e8"
}
```

1. Path under the service account home. A backup account has no reason to hold an authorized_keys file.
2. Event added, realtime mode, size 75 bytes.
3. mtime 15:22:21, one second before the alert. FIM reports the batch time, not always the write time.
4. SHA-256 6195...c5e8. This is the value in the ticket and the escalation note.

HASH HANDLING

Record before deletion

The hash is the only portable identifier after the file is gone.

Compare with known keys

A match on another host turns one incident into a scope question.

Quote it in the ticket

The escalation note carries the value, not a screenshot of it.

Reading is not neutralising

sha256sum only reads bytes. Containment is the deletion and the account action.

> Hash first, delete second. A removed key with no recorded hash cannot be compared against other hosts or against a later re-entry attempt.

6. Post-exploitation trail

auditd recorded the login shell as a hex-encoded command string. Decoding it is one command and it shows exactly what the attacker did next.

soc-lab, INC-001, decoded execve trail

```
$ grep 'bash -c' docs/evidence/INC-001-postex-commands.txt \
    | awk '{print $4}' | xxd -r -p
1 id; whoami; uname -a
  sudo -n -l 2>&1 | head -1
  mkdir -p ~/.ssh
2 echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAILabOnlyPersistenceKey lab-persistence" >>
  ~/.ssh/authorized_keys
3 curl -s -o /dev/null -w "outbound_http=%{http_code}\n" http://10.0.2.2:8080/
  echo POST_EX_DONE
```

1. Identity and host discovery. sudo -n -l fails, so no root path was found.
2. mkdir and the key append. This is the persistence step that rule 100120 later reports.
3. An outbound HTTP check to the gateway. The response code is the only network fact in the trail.

WHAT THE TRAIL PROVES

No privilege escalation

sudo -n -l failed. The account stayed unprivileged.

Persistence executed

The key was appended by the login shell, not by a scheduled job.

No lateral movement

One outbound HTTP check, no internal hosts, no new sessions.

> The window held 292 execve records in 150 seconds. Most were systemd and MOTD noise. Read the trail that follows the successful login, then dismiss the rest.

7. How to capture this evidence

1. **Start broad**

   Discover, index pattern wazuh-alerts-*, absolute 24 hour range, empty query. Screenshot the histogram before you filter anything.

2. **Narrow with stock rules**

   Same window reduced to the minute, then add the rules that ship with Wazuh.

   ```
   data.dstuser:svc-backup and rule.id:(5763 or 40112)
   ```

3. **Narrow with the custom rule**

   ```
   rule.id:100120
   ```

4. **Export the raw alerts, not a screenshot alone**

   A screenshot shows the view. The JSON is the evidence.

   ```
   curl -sk -u admin:"$WAZUH_PASS" \
     'https://localhost:9200/wazuh-alerts-*/_search?size=500' \
     -H 'Content-Type: application/json' \
     -d '{"query":{"bool":{"filter":[
           {"range":{"@timestamp":{"gte":"2026-10-30T15:20:00Z","lte":"2026-10-30T15:24:00Z"}}},
           {"terms":{"rule.id":["5763","40112","100120"]}}]}}}' \
     | jq '.hits.hits[]._source' > INC-001-alerts.json
   ```

5. **Record the SHA-256 before you delete the file**

   The command only reads the file. It does not execute, encrypt, or change it. The digest is the fingerprint you quote in the ticket.

   ```
   ssh -i keys/id_ed25519 -p 2222 analyst@127.0.0.1 \
     'sudo sha256sum /home/svc-backup/.ssh/authorized_keys'
   ```

6. **Decode the execve payload**

   ```
   grep 'bash -c' INC-001-postex-commands.txt \
     | awk '{print $4}' | xxd -r -p
   ```

> Record UTC in the ticket, keep the original JSON unedited, and store the hash next to the evidence path. A screenshot without the export cannot be re-queried later.

8. What to look for

Broad to narrow

A day of alerts, then a minute, then a rule. Each step removes volume and adds a fact.

Volume and timing

Twenty failures in 31 seconds, one account, one source.

Success after failure

Rule 40112 at 15:22:21. The success is the incident.

Persistence within seconds

A FIM change to authorized_keys one second after login. A password reset alone would not remove the access.

Privilege check

sudo -n -l failed. No root, no new account, no sudoers change. That keeps severity at High rather than Critical.

Outbound activity

One HTTP request to 10.0.2.2:8080, returning 200. Scope it before calling it command and control.

COMMON PITFALLS

40112 is noisy

Four of its alerts in this window were routine analyst logins. Filter by account.

10.0.2.2 is shared

Every session in the lab arrives from the gateway. The source IP is not an identity.

FIM timestamps are batched

The alert says 15:22:22.000 while the file mtime is 15:22:21. Use mtime for the timeline.

> Verdict: High severity, contained. The key was hashed, removed, and the account was disabled. Escalated with the hash and the command trail.